

## ASSESSMENT - 3

Name :- J. Vishnu Vardhan

Reg  
Number :- 192324297

course

code :- ITA1434

course

name :- ETHICAL HACKING

## COI - ASSESSMENT-3

### Accidental Denial of Service During a Black-Box Penetration Test.

Introduction :- A black-box penetration test is a security assessment in which the tester has little or no prior knowledge target system. The tester attempts to identify vulnerabilities from an external attackers perspective.

If a tester accidentally causes a denial of service (DoS) condition on a live production server, it becomes a serious security and operational incident. The tester must understand both how the incident could have been prevented and what responsibilities must be fulfilled after the incident.

### 1. What should Have Been Done Before the Test?

#### 1. Obtain proper Authorization

Before starting the penetration test, the tester should obtain written permission from the organization.

The authorization should clearly mention:

- \* Target systems and IP addresses
- \* Testing dates and times.

- \* Testing methods allowed

- \* Testing methods not allowed

- \* Production systems that can be tested

The tester should never assume that general permission to perform a penetration test.

## 2. Define the Rules of Engagement

The Rules of Engagement (RoE) specify how the Penetration test should be conducted.

They should clearly state:

- \* scope of the test

- \* systems included and excluded

- \* Testing limitations

- \* Prohibited activities

For examples, Dos testing should normally be excluded from Production testing unless the organization has specifically approved it.

## 3. Identify Production systems

The testers should determine which systems are:

- \* development systems

- \* Testing systems

## \* staging systems

Risky test should preferably be performed on a staging or isolated environment rather than on a live production server.

This allows the tester to identify vulnerabilities without affecting real users.

## 4. Perform Risk Assessment

Before performing any test, the tester should consider its possible impact.

Questions should include:

- \* could the test overload the server?
- \* could it consume excessive CPU or memory?
- \* could it overload the database?

High-risk activities should receive additional approval and safeguards.

## 5. Use Rate Limiting

Automated testing tools should be configured carefully

The tester should:

- \* start with a low testing rate.

- \* Monitor system behavior

\* increase activity gradually when appropriate  
The goal is to identify security weakness without unnecessarily affecting availability.

6> Monitor the Target

Monitor should be available during the test.

Important metrics include:

\* CPU utilization

\* Memory utilization

\* Network traffic

\* Application errors

If the indicators suddenly become abnormal, testing should be stopped immediately.

2. What should the Tester do when the DoS occurs?

When the Production server becomes unavailable the tester should immediately stop the test.

\* stop the responsible process

\* do not continue testing

\* Inform the security / operations team.

\* Preserve relevant logs

3> Notify the organizations

Tester should report the incident quickly and honestly

The report should include:

- \* what happened
- \* when it happened
- \* Affected system
- \* Test being performed

4> Support Incident Response

The tester should cooperate with the incident-response team by providing:

- \* Testing logs
- \* Timeline
- \* Tool/configuration details

The authorized technical team should handle production recovery.

5> Preserve Evidence

The tester should securely preserve:

- \* Test logs
- \* Timestamps
- \* Error messages

## 6> Determine Root Cause

After recovery, the team should determine

- \* which test caused the problem?
- \* why did the server become unavailable?
- \* were rate limits sufficient?
- \* was monitoring adequate?

The goal is to prevent the same problem in the future.

## 7> Tester's Responsibility

The tester must:

- \* stay within the agreed scope
- \* minimize damage
- \* report incident immediately
- \* cooperate with recovery.
- \* Follow professional and ethical standards.

## 8> What the Tester should NOT DO

The tester should not:

- \* Hide the incident
- \* delete logs
- \* continue the test.
- \* Make unauthorized repairs
- \* Modify production data unnecessarily.

## 2 Post-Incident Report

The final report should contain:

- \* Incident summary
- \* Timeline
- \* Technical cause
- \* Impact
- \* corrective actions

Recommended improvement include better monitoring rate limiting safer testing environment and clearer rules of Engagement

### Conclusion :-

An accidental Dos is a serious incident. The tester should stop, report preserve evidence cooperate with recovery document the incident and prevent recurrence. The main principle is to improve security while causing minimum disruption to production services.